



Cybersecurity

Penetration Test Report Template

MegaCorpOne

Penetration Test Report

WeSecurity, LLC

Confidentiality Statement

This document contains confidential and privileged information from MegaCorpOne Inc. (henceforth known as MegaCorpOne). The information contained in this document is confidential and may constitute inside or non-public information under international, federal, or state laws. Unauthorized forwarding, printing, copying, distribution, or use of such information is strictly prohibited and may be unlawful. If you are not the intended recipient, be aware that any disclosure, copying, or distribution of this document or its parts is prohibited.

Table of Contents

Confidentiality Statement	2
Contact Information	4
Document History	4
Introduction	5
Assessment Objective	5
Penetration Testing Methodology	6
Reconnaissance	6
Identification of Vulnerabilities and Services	6
Vulnerability Exploitation	6
Reporting	6
Scope	7
Executive Summary of Findings	8
Grading Methodology	8
Summary of Strengths	9
Summary of Weaknesses	9
Executive Summary Narrative	10
Summary Vulnerability Overview	11
Vulnerability Findings	12
MITRE ATT&CK Navigator Map	13

Contact Information

Company Name	WeSecurity, LLC
Contact Name	Wesdariusz Dimaculangan
Contact Title	Penetration Tester
Contact Phone	555.224.2411
Contact Email	Wdimaculangan@Wesecurity.com

Document History

Version	Date	Author(s)	Comments
001	01/22/2024	Wesdariusz D.	

Introduction

In accordance with MegaCorpOne's policies, WeSecurity, LLC (henceforth known as WeSec) conducts external and internal penetration tests of its networks and systems throughout the year. The purpose of this engagement was to assess the networks' and systems' security and identify potential security flaws by utilizing industry-accepted testing methodology and best practices. The project was conducted on a number of systems on MegaCorpOne's network segments by WeSec during January of 2024.

For the testing, WeSec focused on the following:

- Attempting to determine what system-level vulnerabilities could be discovered and exploited with no prior knowledge of the environment or notification to administrators.
- Attempting to exploit vulnerabilities found and access confidential information that may be stored on systems.
- Documenting and reporting on all findings.

All tests took into consideration the actual business processes implemented by the systems and their potential threats; therefore, the results of this assessment reflect a realistic picture of the actual exposure levels to online hackers. This document contains the results of that assessment.

Assessment Objective

The primary goal of this assessment was to provide an analysis of security flaws present in MegaCorpOne's web applications, networks, and systems. This assessment was conducted to identify exploitable vulnerabilities and provide actionable recommendations on how to remediate the vulnerabilities to provide a greater level of security for the environment.

WeSec used its proven vulnerability testing methodology to assess all relevant web applications, networks, and systems in scope.

MegaCorpOne has outlined the following objectives:

Table 1: Defined Objectives

Objective
Find and exfiltrate any sensitive information within the domain.
Escalate privileges to domain administrator.
Compromise at least two machines.

Penetration Testing Methodology

Reconnaissance

WeSec begins assessments by checking for any passive (open source) data that may assist the assessors with their tasks. If internal, the assessment team will perform active recon using tools such as Nmap and Bloodhound.

Identification of Vulnerabilities and Services

WeSec uses custom, private, and public tools such as Metasploit, hashcat, and Nmap to gain perspective of the network security from a hacker's point of view. These methods provide MegaCorpOne with an understanding of the risks that threaten its information, and also the strengths and weaknesses of the current controls protecting those systems. The results were achieved by mapping the network architecture, identifying hosts and services, enumerating network and system-level vulnerabilities, attempting to discover unexpected hosts within the environment, and eliminating false positives that might have arisen from scanning.

Vulnerability Exploitation

WeSec's normal process is to both manually test each identified vulnerability and use automated tools to exploit these issues. Exploitation of a vulnerability is defined as any action we perform that gives us unauthorized access to the system or the sensitive data.

Reporting

Once exploitation is completed and the assessors have completed their objectives, or have done everything possible within the allotted time, the assessment team writes the report, which is the final deliverable to the customer.

Scope

Prior to any assessment activities, MegaCorpOne and the assessment team will identify targeted systems with a defined range or list of network IP addresses. The assessment team will work directly with the MegaCorpOne POC to determine which network ranges are in-scope for the scheduled assessment.

It is MegaCorpOne's responsibility to ensure that IP addresses identified as in-scope are actually controlled by MegaCorpOne and are hosted in MegaCorpOne-owned facilities (i.e., are not hosted by an external organization). In-scope and excluded IP addresses and ranges are listed below.

IP Address/URL	Description
172.16.117.0/16 MCO.local *.Megacorpone.com	MegaCorpOne internal domain, range and public website

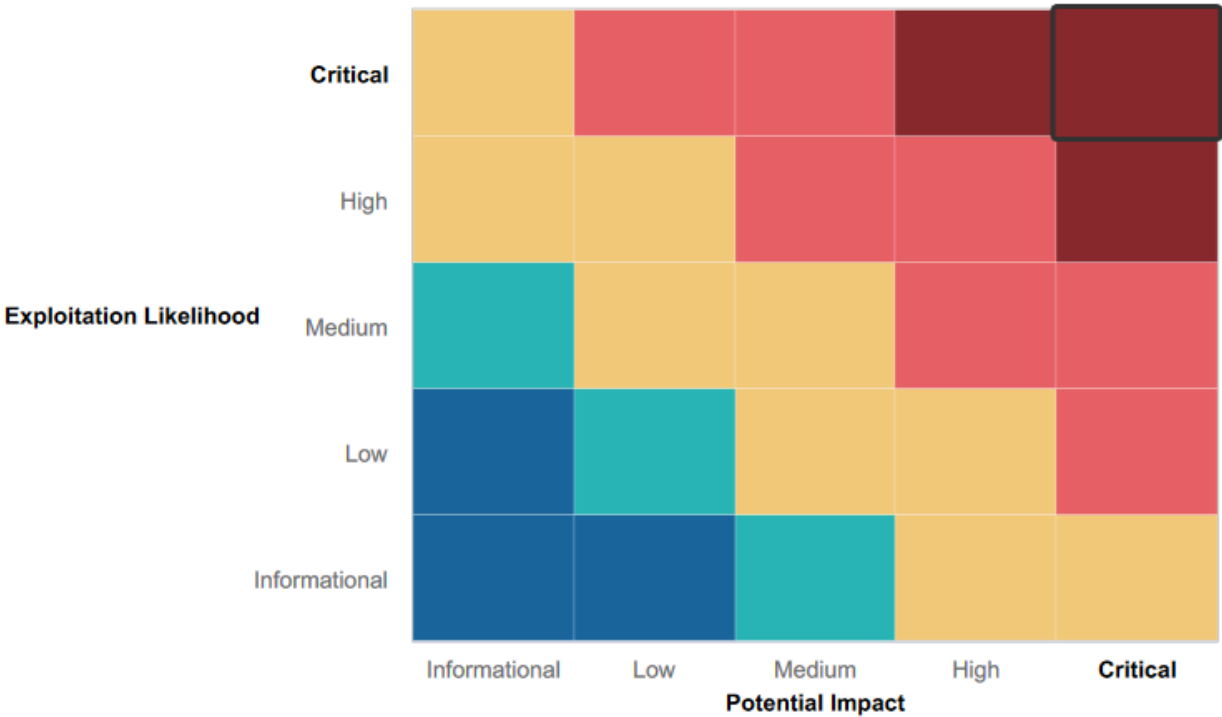
Executive Summary of Findings

Grading Methodology

Each finding was classified according to its severity, reflecting the risk each such vulnerability may pose to the business processes implemented by the application, based on the following criteria:

- Critical:** Immediate threat to key business processes.
- High:** Indirect threat to key business processes/threat to secondary business processes.
- Medium:** Indirect or partial threat to business processes.
- Low:** No direct threat exists; vulnerability may be leveraged with other vulnerabilities.
- Informational:** No threat; however, it is data that may be used in a future attack.

As the following grid shows, each threat is assessed in terms of both its potential impact on the business and the likelihood of exploitation:



Summary of Strengths

While the assessment team was successful in finding several vulnerabilities, the team also recognized several strengths within MegaCorpOne’s environment. These positives highlight the effective countermeasures and defenses that successfully prevented, detected, or denied an attack technique or tactic from occurring.



Summary of Weaknesses

WeSec successfully found several critical vulnerabilities that should be immediately addressed in order to prevent an adversary from compromising the network. These findings are not specific to a software version but are more general and systemic vulnerabilities.

- FTP Backdoor vulnerabilities
- Weak Password (easily guessed)
- Some ports are open
- Admin passwords are saved in plain text
- Server CVE Vulnerabilities

Executive Summary

WeSecurity was able to locate and exfiltrate sensitive information, escalate our privileges to the Domain Admin, and compromise at least two(2) machines.

Several vulnerabilities were found throughout our testing. Most of these vulnerabilities stem from the acceptance of weak passwords. In the course of our testing, we discovered that we could identify and extract additional usernames and passwords from both Linux and Windows computers by first guessing and then using a weak password to get access to those systems. We were able to elevate our privileges to the maximum level, which gave us backdoor access to the system and the ability to make lateral movement between machines.

Our investigation also turned several open port vulnerabilities that might be used to create backdoor access. We were able to find Megacorpone's DNS server's IP address using OSINT, making them accessible to assault via those entry ports. We also discovered that Megacorpone is vulnerable to LLMNR attacks. We discovered that Megacorpone's Apache servers have various vulnerabilities after conducting a Shodan report, including CVE alerts in the report are based on publicly disclosed security vulnerabilities.

Our report's vulnerability findings section goes in-depth about each vulnerability we identified and our recommended fixes. The majority of the recommendations should be quite simple and inexpensive to execute, even though certain important areas need to be addressed.

Summary Vulnerability Overview

Vulnerability	Severity
Weak password on public web application	Critical
Ports open	Critical
FTP Backdoor vulnerabilities	Critical
Plain text password storage	High
Server CVE Vulnerabilities	Medium

The following summary tables represent an overview of the assessment findings for this penetration test:

Scan Type	Total
Hosts	172.22.117.150 172.22.117.10 172.22.117.20 256 IP scanned
Ports	Ports 21,22,80,443,445,139,3389,88

Exploitation Risk	Total
Critical	3
High	1
Medium	1
Low	0

Vulnerability Findings

Weak Password on Public Web Application

Risk Rating: Critical

Description:

The site **vpn.megacorpone.com** is used to host the Cisco AnyConnect configuration file for MegaCorpOne. This site is secured with basic authentication but is susceptible to a dictionary attack. WeSec was able to use a username gathered from OSINT in combination with a wordlist in order to guess the user's password and access the configuration file.

Affected Hosts: vpn.megacorpone.com

Remediation:

- Set up two-factor authentication instead of basic authentication to prevent dictionary attacks from being successful.
- Require a strong password complexity that requires passwords to be over 12 characters long, upper+lower case, & include a special character.
- Reset the user **thudson**'s password.

CVE Vulnerabilities

Risk Rating: Medium

Description:

Running Shoden we discovered a potential vulnerability on the Megacorpone Apache server: CVE-2019-0215, CVE-2019-0220, CVE-2019-0217, CVE-2019-0197, CVE-2019-0196, CVE-2019-0211

Affected Hosts: Apache Server

Remediation:

- CVEs are known security vulnerabilities. Although we didn't precisely test to see whether Megacorp's system has these vulnerabilities, we nonetheless advise Megacorp to educate themselves on them.
- Details about these vulnerabilities can be found at [CVE - Search CVE List \(mitre.org\)](https://cve.mitre.org/cve/search-cve-list/)

FTP Backdoor vulnerabilities

Risk Rating: Critical

Description:

Using Zenmap scan with a custom profile we can identify an FTP Backdoor in the system.

Affected Hosts:

172.22.117.150 on port 23

Remediation:

- Switch to SFTP, a Secure file transfer protocol, Works over a secure connection to protect Megacorpone's business and customers.
- Update Magacorpone's server.
- Create a firewall rules. Among the most crucial components is this one. Consider an iptables rule to restrict connections from those IP Addresses if Megacorpone only uses one or two devices to access the server.

MITRE ATT&CK Navigator Map



The following completed MITRE ATT&CK navigator map shows all of the techniques and tactics that WeSec used throughout the assessment.

Legend:

Performed successfully

Failure to perform